Reference

SAA-C03 · ALL MODULES

AWS SAA-C03 Exam Cheat Sheet

Distilled from all 19 lesson modules (05–23) · weighted by two r/AWSCertifications exam-report threads · built 2026-09-13

Primary source: Adrian Cantrill SAA-C03, cross-checked against current AWS docs (see each lesson's own citations in `RESOURCES.md`). Exam-strategy section paraphrased from two recent SAA-C03 exam-report posts shared by the learner.

⚠ TWO TOPICS YOUR LESSONS DON'T COVER YET

One of the two source Reddit exam reports named **Amazon EMR & EMR Clusters** and **FSx for NetApp ONTAP** as tested on their exam. Neither exists anywhere in this workspace's 19 modules — there is no Hadoop/Spark/big-data lesson at all, and only FSx for Windows File Server + FSx for Lustre are covered (no ONTAP or OpenZFS). Nothing below fills that gap with invented content, per this workspace's citation rules. Recommend building two short lessons: EMR (transient vs. long-running clusters, master/core/task nodes, Hadoop/Spark/Hive, EMRFS on S3, Spot for task nodes) and FSx for ONTAP (multi-protocol NFS+SMB+iSCSI, snapshots/clones, the natural "lift-and-shift on-prem NetApp" answer — contrast with FSx-Windows being SMB/AD-only and FSx-Lustre being HPC/Linux-only).

Exam-day strategy

Paraphrased from two recent SAA-C03 exam-report posts. These are heuristics from people who just passed — not official AWS doctrine — but they're worth internalizing before you read a single service fact below.

1. Read the last sentence first

Before reading the scenario, read the question stem. It usually contains one keyword that eliminates most options outright:

Keyword	What it usually means
MOST cost-effective	Prefer Spot/Reserved/Savings Plans, S3 lifecycle/Intelligent-Tiering, serverless-to-zero, versioned filenames over invalidation — the cheapest option that still meets every stated requirement.
LEAST operational overhead	Prefer the most fully-managed option (Aurora Serverless over self-managed HA, Fargate over EC2 mode, managed service over EC2/DIY).
LEAST application code changes	Prefer drop-in/transparent options; rule out anything requiring the app to be rewritten (e.g. ElastiCache needs app changes to check cache — DAX for DynamoDB is closer to drop-in).
Highest/high availability	Multi-AZ, multiple NAT Gateways (one per AZ), cross-zone load balancing, Auto Scaling across AZs.
Lowest latency	Caching layer (CloudFront/DAX/ElastiCache), edge locations, Global Accelerator, placement groups, provisioned concurrency.
Disaster recovery / DR	Cross-Region replication/snapshots, Aurora Global Database, S3 CRR, pilot-light/warm-standby patterns.
Secure without internet exposure	VPC endpoints (gateway/interface), PrivateLink, no public subnet/IGW involved at all.

2. The fast-kill elimination pattern

Most 4-option SAA-C03 questions are built the same way: **1 clearly wrong**, **1 technically possible but violates a stated requirement**, **2 plausible**, and **1 best**. Kill the first two immediately, then use the keyword from step 1 to

pick between the remaining two plausible options. This workspace's own scenario quizzes are deliberately built with exactly this structure (see `NOTES.md`) so practicing on them trains the right muscle.

3. Identify the core domain being tested

A large share of questions secretly reduce to one of a small number of recurring decision points — memorize these cold and most of the surrounding scenario detail becomes noise. See the 8 high-yield decision points below.

4. The "overengineering" filter

If an answer introduces an extra Region, an extra service not mentioned in the scenario, custom-built management, or unnecessary complexity, it's usually wrong. AWS's implicit exam bias is **Simple + Managed + Meets the stated requirement** — not the most powerful or most impressive-sounding architecture.

5. When stuck between two answers

Ask, in order: which one is more AWS-managed? Which one removes more operational responsibility from you? Which one most precisely matches the exact requirement wording (not just "close enough")? The more-managed option usually wins unless the question explicitly wants low-level control (e.g. RDS Custom, EC2, self-managed AD).

6. Time management

65 questions, 130 minutes = 2 minutes/question. First pass: answer everything you're ~70% confident in, flag the rest, move on. Don't spend 5+ minutes on one question — most people fail by getting stuck early, not by running out of raw knowledge. You need roughly 72%, not 100%.

7. Don't panic on a hard streak

Seeing 3 difficult questions in a row is normal, not a sign you're failing. Keep moving.

The 8 high-yield decision points

One exam-report thread named these explicitly as the recurring "core domains" behind a large share of SAA-C03 questions. If you only have time to drill eight things before the exam, drill these.

RDS Multi-AZ instance vs. Multi-AZ cluster vs. Read Replica

Synchronous vs. asynchronous replication is the whole story — see Module 12.

NAT Gateway vs. Internet Gateway

1:1 static NAT, bidirectional, one-per-VPC vs. many:1, outbound-only, one-per-AZ for HA — see Module 07.

CloudFront vs. Global Accelerator

HTTP(S) caching vs. protocol-agnostic Anycast routing, never cached — see Module 16.

Route 53 routing policies (all six)

Simple/Failover/Multivalue/Weighted/Latency/Geolocation/Geoproximity — see Module 11.

Gateway Endpoint vs. Interface Endpoint

S3/DynamoDB-only + free + auto-HA vs. everything else + ENI-based + PrivateLink — see Module 17.

Snowball (Edge) vs. Direct Connect vs. DataSync

Bulk one-time transfer with no network path vs. dedicated ongoing connectivity vs. reliable scheduled transfer over an existing link — see Module 18.

EFS vs. EBS vs. FSx

Shared POSIX file storage vs. single-instance block storage vs. native Windows/HPC file systems — see Modules 08 & 13 & 18.

IAM Role vs. IAM User

Named, countable principal with long-term creds vs. any trusted principal with short-term STS creds — see Module 05.

05 · IAM, Accounts & Organizations

IAM identity policies

- JSON document attached to a user/group/role. Statement fields: `Sid` (optional), `Effect` (Allow/Deny, required), `Action`, `Resource`.
- Evaluation order: **Explicit Deny** → **Explicit Allow** → **Implicit Deny** — deny always wins, default is implicit deny.
- Managed (AWS or customer) vs. inline: prefer managed for central updates; inline only for one-off single-identity exceptions.

IAM users, ARNs & Roles ⚡ HIGH YIELD

- **Decision rule: use an IAM User only if you can name exactly one thing using it.** Otherwise — or beyond 5,000 principals — use a Role.
- ARN format: `arn:partition:service:region:account-id:resource-id`. An empty segment means "not required for that resource type" (S3 has no region/account); `*` is a wildcard, not the same as an empty segment.
- Hard limits: **5,000 IAM users per account**; a user can belong to a **max of 10 groups**.

	IAM User	IAM Role
Who uses it	One named entity	Any trusted principal
Credentials	Long-term	Short-term / temporary (STS)
Good for	Known, countable principals	Services, federation, unknown count

- Every role has **two policies**: a trust policy (who can assume it) and a permission policy (what it can do once assumed).
- Assume-role flow: STS `AssumeRole` → trust policy check → temporary access key + secret + session token with an expiry.
- **A Role can be a Principal in a resource policy; a Group cannot** — recurring exam trap. Groups have no permissions of their own, can't be nested, and can't be a policy Principal.
- Five scenarios that always mean "use a Role": (1) an AWS service acting on your behalf, (2) emergency/break-glass access, (3) federation with a corporate IdP (bypasses the 5,000-user cap), (4) web identity federation (Google/Facebook logins), (5) cross-account access — the trusting account needs no IAM user for the trusted account's principal.

- **Service-linked roles**: permissions are fixed/predefined by the service, can't be edited, and can't be deleted while the service is using them.
- `iam:PassRole` is required to *attach* an existing role to a service (e.g. launching an EC2 instance with a role) without needing rights to create/edit roles — this is what prevents privilege escalation via role attachment.

AWS Organizations & Service Control Policies (SCPs) ⚡ HIGH YIELD

- One management (master) account + N member accounts. **The management account is never restricted by SCPs, even at the root** — best practice is to never run production workloads there.
- Org Root → OUs (nestable) → accounts, with consolidated billing across every member account.
- Recommended cross-account pattern: log into one identity account and **assume roles** into member accounts — no per-account IAM users.
- SCPs set the **maximum permission boundary**; they never grant, only restrict. Effective access is always the **intersection** of what the SCP allows and what IAM allows.
- Attach at Org Root (everything except the management account), an OU (cascades to nested OUs), or an individual account.
- **Deny list** (default): the `FullAWSAccess` SCP stays attached, add explicit Denies. **Allow list**: remove `FullAWSAccess`, add an explicit Allow-only SCP.

> 💡 **EXAM TRAP**
>
> An `AdministratorAccess` IAM policy does **not** override a restrictive SCP. The SCP is a ceiling regardless of how permissive the IAM side is.

CloudWatch Logs vs. CloudTrail

- CloudWatch Logs hierarchy: Log Event (timestamp + message) → Log Stream (one source) → Log Group (retention/permissions are set **here**, not per-stream).
- A metric filter on a log group produces a numeric metric → CloudWatch Alarm → SNS/Auto Scaling action.
- **CloudTrail** records every API call (who did what, when). Enabled by default, 90 days of free event history in the console; deliver to S3 for longer retention.
  - One-region trail vs. all-regions trail (recommended — also captures global services like IAM/STS/CloudFront).
  - **Management events** (control-plane, default, first copy free per Region) vs. **data events** (S3 object ops, Lambda invocations — data-plane, not default, extra cost).
  - **Not real-time** — roughly a 15-minute delay. Use EventBridge for real-time alerting.

> 💡 **MENTAL HOOK**
>
> "Who did what, when?" → CloudTrail. "What's happening right now?" → CloudWatch.

AWS Control Tower

- Sits on top of Organizations and adds automated governance. **Landing Zone** = the governed multi-account environment it provisions.
- Guardrails: **Preventive = SCPs** (blocks actions) vs. **Detective = AWS Config rules** (flags non-compliant resources after the fact, doesn't block them).
- **Account Factory** = self-service standardized account provisioning.

06 · Simple Storage Service (S3)

Bucket policies vs. IAM policies

- Private by default (root + creator only). A bucket policy is a resource policy — it has a `Principal` field, which identity policies never have. Quick tell for "is this a resource policy?": does it have a `Principal` key.
- One bucket has one bucket policy, which can hold multiple statements.
- Same-account IAM identity accessing the bucket = union of IAM policy + bucket policy (both must allow). Anonymous access = bucket policy only (no identity to attach a policy to). Cross-account = both accounts' policies must allow.
- Use a bucket policy when many identities need one bucket, or when anonymous/public access is required. Use an IAM identity policy when one identity needs many buckets, or centralized IAM management is a requirement.

Static website hosting & performance

- Requires an index document + an error document. Classic scenario: "our servers are down, we need a maintenance page" → host a static page in S3 and repoint DNS.
- Single-stream upload is only practical to about 5 GB. **Multipart upload**: recommended above ~100 MB, up to 10,000 parts, 5 MB–5 GB per part.
- **Transfer Acceleration** routes uploads via the nearest edge location over AWS's backbone — best when the uploader and bucket are geographically far apart; bucket name must be DNS-compatible (no dots); disabled by default, enabled per bucket.

Versioning & MFA Delete

- States: Disabled → Enabled → **Suspended only** — you can never go back to Disabled. Classic distractor.
- Deleting without a version ID adds a recoverable delete marker; deleting with a specific version ID is permanent.
- MFA Delete is required for (1) changing the versioning state itself, and (2) permanently deleting a specific version.

Encryption: KMS, CSE vs. SSE

- KMS keys directly encrypt/decrypt only up to 4 KB — anything larger uses a **data encryption key (DEK)** via `GenerateDataKey` (returns a plaintext DEK to use-and-discard plus a ciphertext DEK to store; KMS never stores the DEK itself).
- Key types: AWS-owned (no control) / AWS-managed (not configurable, can't disable) / customer-managed CMK (fully configurable, including rotation). Rotation keeps old key material, so nothing needs re-encrypting.

- KMS's core value on the exam is **role separation** — you can grant `GenerateDataKey` without `Decrypt`.

Type	Key owner	Who does the crypto	Role separation?
SSE-C	Customer	S3	No
SSE-S3 (default)	AWS	S3	**No** — a full S3 admin can decrypt everything
SSE-KMS	Customer-managed KMS key	S3 + KMS	**Yes**

- Since 2023, AWS mandates SSE on all new S3 objects — no unencrypted storage.
- **S3 Bucket Keys**: an optimization for SSE-KMS at scale — KMS issues one time-limited bucket key, and S3 generates per-object DEKs locally instead of calling KMS every time, cutting cost/throttling.

> 💡 **EXAM TRIGGER**
>
> "Prevent S3 admins from reading the data" or "audit key usage/rotation" → SSE-KMS.

Storage classes ⚡ HIGH YIELD

Class	AZs	Retrieval fee	Min duration	Min object size	Latency
Standard	3	None	None	None	ms
Standard-IA	3	Per-GB	30 days	128 KB	ms
One Zone-IA	1	Per-GB	30 days	128 KB	ms
Glacier Instant Retrieval	3	Per-GB	90 days	—	ms (instant)
Glacier Flexible Retrieval	3	Per-GB	90 days	40 KB	Expedited 1–5 min / Standard 3–5 hr / Bulk 5–12 hr
Glacier Deep Archive	3	Per-GB	180 days	40 KB	Standard ~12 hr / Bulk ~48 hr
Intelligent-Tiering	varies	None (monitoring fee instead)	None	—	auto-tiers by access pattern

Decision rule: known, stable access pattern → pick a specific class. Unknown/variable access → Intelligent-Tiering.

Lifecycle configuration

- **Time-based, not access-based** (access-based tiering is Intelligent-Tiering's job).
- Transitions are one-way: Standard → Standard-IA → Intelligent-Tiering → One Zone-IA → Glacier Instant → Glacier Flexible → Deep Archive (One Zone-IA can't jump straight to Glacier Instant).
- Objects must sit 30 days in Standard before a lifecycle rule can move them to Standard-IA/One Zone-IA (doesn't apply if uploaded directly into those classes).

Replication (CRR/SRR) ⚡ HIGH TRAP DENSITY

- CRR = cross-Region; SRR = same-Region (log aggregation, prod→test, data sovereignty).
- Requires **versioning enabled on both source and destination**. Config lives on the source bucket: destination bucket + an IAM role that can read source/write destination. Cross-account also needs a destination bucket policy allowing the source role.

- **Not retroactive** — only objects written after enabling replicate; use Batch Replication for pre-existing objects.
- Delete markers are **not** replicated by default. Lifecycle actions are not replicated. Glacier/Deep Archive objects are not replicated. One-way by default.
- Replication Time Control (RTC) is an optional 15-minute SLA add-on.

Pre-signed URLs

- Encodes the generating identity's permissions; valid **at time of use, not creation** — if the generator loses access, the URL breaks even if it hasn't expired yet.
- **Avoid generating from an IAM role** — the role's temporary credentials often expire faster than the URL's intended lifetime. Use a long-lived IAM user identity instead.
- Exam triggers: share a private object externally without making it public; time-limited PUT (upload) access.

S3 Select / Glacier Select vs. Athena, S3 Events vs. EventBridge

- S3/Glacier Select run a SQL-like filter server-side **inside one large object**. For SQL across *many* objects in a bucket, that's Amazon Athena instead — a common exam distractor pairing.
- S3 Events go to SNS/SQS/Lambda only — simple, single-destination triggers. EventBridge supports 50+ targets, content-based filtering and transformation, and cross-service routing — pick it for complex/multi-target scenarios.

Access logs & Object Lock (WORM)

- Access logs: a source bucket (logged) and a target bucket (receives logs); log delivery needs an ACL write grant on the target. Best-effort delivery (hours), not real-time, no auto-expiry — set your own lifecycle rules on the target.
- Object Lock requires versioning and applies to specific object versions.

Mode	Bypassable?	Retention shortenable?
Governance	Yes, with `s3:BypassGovernanceRetention`	Yes (with bypass)
Compliance	**No — not even root**	**No**
Legal Hold	On/off flag, no period; needs `s3:PutObjectLegalHold`	N/A

> 💡 **EXAM TRIGGER**
>
> "A regulator requires immutability for N years, no one including root can delete" → Compliance mode.

Access Points

- A named endpoint per bucket with its own DNS, policy, and optional VPC restriction — turns one unwieldy bucket policy into per-team scoped policies.
- **Delegation pattern**: the bucket policy grants broad access via any access point; each access point policy does the fine-grained restriction. Both must allow — the access point policy alone is not sufficient.

07 · Virtual Private Cloud (VPC) Basics

VPC fundamentals, subnets & routing

- Regional, spans every AZ in the Region automatically; each VPC is an isolated blast radius.
- CIDR range: **/28 (16 IPs, smallest) to /16 (65,536 IPs, largest)**. One mandatory primary CIDR + optional secondary CIDRs.
- The VPC's DNS resolver always lives at **base-of-CIDR + 2** (e.g. 10.0.0.0/16 → resolver at 10.0.0.2). `enableDnsSupport` (default true) turns the resolver on; `enableDnsHostnames` (default false) assigns public DNS hostnames — you need both for public DNS names on instances.
- One subnet = exactly one AZ, never spans AZs. **5 reserved IPs per subnet** (network address, +1 VPC router, +2 DNS resolver, +3 AWS reserved, last = broadcast) — a /28 has 16 raw addresses but only 11 usable.
- Route tables: **longest-prefix-match wins**, ties go to the `local` target. The main route table (AWS-created, undeletable, default association) vs. custom route tables you create and assign to specific subnets (one at a time per subnet).
- Making a subnet public = a custom route table with `0.0.0.0/0 → IGW`.

Internet Gateway vs. NAT Gateway ⚡ HIGH YIELD

	Internet Gateway	NAT Gateway
Mapping	1 private IP ↔ 1 public IP (static NAT)	Many private IPs → 1 public IP
Direction	In + out	**Outbound-initiated only** (responses allowed back)
Public IP	EIP or dynamic	Elastic IP (static)
Resilience	Region-resilient (one per VPC)	**AZ-resilient only** — need one per AZ for full HA

- IGW does 1:1 static NAT for IPv4 — the OS never sees the public IP. **IPv6 gets no translation** at all — it's publicly routable end to end and passes through the IGW unchanged. Zero or one IGW per VPC, never more.
- NAT Gateway setup: it lives in a public subnet with an EIP; the private subnet's route table sends `0.0.0.0/0 → NAT GW`.
- **HA design: one NAT Gateway per AZ**, with each AZ's private subnets routing to their own AZ's NAT GW. A single NAT Gateway shared across all AZs is a classic exam failure scenario — that AZ's outage kills

outbound internet for every private subnet routed to it.

- NAT Gateway vs. NAT Instance: NAT Gateway is fully managed, scales to 45 Gbps, has no Security Groups (NACL only), and handles source/destination check automatically. A NAT Instance (plain EC2) is self-managed, is SG-capable, can double as a bastion, and needs source/dest check manually disabled.

> **⚠ STALE COURSE FACT, CORRECTED**
>
> The lessons still teach "NAT Gateway does not work with IPv6 at all." AWS has since added **NAT64/DNS64**, letting a NAT Gateway translate IPv6-only resources to IPv4 destinations. It still has no native IPv6↔IPv6 pass-through, so an **Egress-Only Internet Gateway** remains the right answer for pure IPv6 outbound-only needs — but "NAT Gateway + IPv6 = never" is no longer strictly true.

Stateful vs. stateless firewalls: Security Groups vs. NACLs ⚡ HIGH YIELD

- A request uses a well-known port (e.g. 443); the response uses the client's random ephemeral port (1024–65535).
- **Stateless (NACLs)**: no memory — you must explicitly allow both directions, including the full ephemeral range outbound. Forgetting the ephemeral outbound rule is the #1 NACL mistake.
- **Stateful (Security Groups)**: allow the request and the response is auto-permitted — one rule needed.

	Network ACL	Security Group
Scope	Subnet boundary	Attached to the ENI
State	Stateless	Stateful
Rules	Numbered, lowest first, first match wins	Allow-only, no explicit deny
Explicit deny by IP?	**Yes**	**No**
Can reference other AWS resources?	No — IP/CIDR/port/protocol only	**Yes** — e.g. "allow from sg-webserver"
Default	Allow-all in+out, auto-associated to unassigned subnets	N/A
Custom	Implicit deny until rules added, no subnet association until assigned	N/A

- The `*` implicit-deny NACL rule always sits at the bottom and can't be removed. One NACL per subnet, but one NACL can cover many subnets.

- **Self-referencing SG rule**: allow all traffic from members of this same SG — the canonical pattern for intra-tier/cluster communication that survives scaling in/out.

> 💡 **EXAM TRIGGER**
>
> "Block a specific bad IP address" → NACL (Security Groups cannot explicitly deny anything).

Bastion hosts

- An EC2 instance in a public subnet acting as a hardened single entry point — admins SSH/RDP in, then hop to private instances.
- **Bastion = inbound admin access to private instances. NAT Gateway = outbound internet access for private instances.** Different problems — don't conflate them.

08 · Elastic Compute Cloud (EC2) Basics

EC2 architecture & resilience

- **EC2 is AZ-locked, full stop** — host, ENI, subnet, and EBS all live in exactly one AZ; no cross-AZ attach for ENI or EBS.
- An instance can move host (same AZ only) on host failure/maintenance, or a stop→start (not a plain reboot). It never moves AZ natively — only via an AMI/snapshot and relaunch.

Instance types

- Five categories: General purpose (balanced, default), Compute optimized (more CPU/$), Memory optimized (more RAM/$), Accelerated computing (GPU/FPGA/ML-inference), Storage optimized (large, fast local disk).
- Family letter mnemonics: **C**ompute, **R**AM, **I**/O, **D**ense storage, **G**PU.
- Burstable/T-series (credit-based, cheap, low-baseline-CPU workloads) vs. steady-state/M-series (consistent load).

EBS volume types ⚡ HIGH YIELD

- **EBS is AZ-locked**, same rule as EC2 — a snapshot to S3 is the only way to move data cross-AZ/Region. Volumes are decoupled from instance lifecycle (persist across stop/start), and multi-attach is supported by some types for clusters (the app must coordinate writes itself).

Family	Types	Size	Max IOPS/vol	Max throughput/vol	Notes
General purpose SSD	gp2 / gp3	1 GiB–16 TiB	16,000	250–1,000 MB/s	gp3 decouples size from performance entirely; ~20% cheaper than gp2 at equal baseline
Provisioned IOPS SSD	io1 / io2	4 GiB–16 TiB	64,000	1,000 MB/s	Use for sub-ms latency or small volumes needing very high IOPS
Provisioned IOPS SSD	io2 Block Express	4 GiB–64 TiB	256,000	4,000 MB/s	Highest IOPS:GB ratio (1000:1)
HDD — Throughput Optimized	st1	125 GB–16 TB	—	500 MB/s max	Sequential only, **cannot be a boot volume**, big data/log processing
HDD — Cold	sc1	125 GB–16 TB	—	250 MB/s max	Sequential only, **cannot be a boot volume**, archives/cold backups

Memorize the ordering: gp2/gp3 (16K IOPS) < io1/io2 (64K) < io2 Block Express (256K) < instance store.

- **Instance Store**: physically attached, highest raw performance, but fully **ephemeral** — wiped on stop/start, host migration, type change, or hardware failure. Can only be attached at launch time.
- **Snapshots**: incremental, S3-backed, region-resilient. First snapshot = full copy of used data only; later ones store only changed blocks. Restored volumes lazy-load from S3 unless you enable **Fast Snapshot Restore** (per snapshot per AZ, 50/Region limit, paid).
- **EBS Encryption**: uses KMS; a brand-new volume gets a new DEK, but a snapshot of an encrypted volume (and anything restored from it) reuses the source's DEK. You cannot decrypt in place — only path is an OS-level copy to a new unencrypted volume.

ENIs, IPs & DNS

- Every instance has a primary ENI (can't detach) plus optional secondary ENIs (detachable, same-AZ only). SGs attach **per ENI** — different SG rulesets per IP need separate ENIs.
- Public DNS hostnames resolve to the private IP from inside the VPC, and the public IP from outside — dual resolution avoids an IGW hairpin for intra-VPC traffic.
- Public IPv4 is **dynamic** (released on stop, reassigned on start; reboot doesn't change it). An Elastic IP is static. The OS never sees the public IPv4 — only IPv6 is exempt from NAT.

AMIs

- **Region-specific** — must be explicitly copied to use in another Region. Not AZ-specific (built from S3-backed snapshots, so it launches into any AZ in its Region).
- Cannot be edited directly — must launch, modify, and create a new AMI.

EC2 purchase options

- **On-Demand**: default assumption, per-second billing, no commitment, no interruption, no capacity priority during a shortage (Reserved is served first).
- **Spot**: up to ~90% discount, reclaimed with short notice if price exceeds your max — good for parallel/batch/fault-tolerant/stateless work, never for anything interruption-intolerant.
- **Reserved Instances**: 1 or 3-year term; billed for the commitment even if unused. **Savings Plans** commit to $/hour spend instead of a specific instance type — Compute Savings Plans (EC2+Fargate+Lambda, most flexible) vs. EC2 Instance Savings Plans (EC2 only, deepest single-service discount).
- **Dedicated Hosts** (pay for the whole physical host, socket/core visibility — driven by per-socket/per-core licensing) vs. **Dedicated Instances** (isolated hardware, no host visibility, small hourly fee — driven by "don't share hardware" compliance without a licensing angle).

Status checks, scaling & IMDS ⚡ HIGH YIELD SECURITY TOPIC

- **System status check** = AWS/host infrastructure problem → fix by stop/start (moves to a new host); a reboot won't help. **Instance status check** = your OS/config problem → fix by reboot or rebuild.
- Vertical scaling has a hard ceiling and usually needs downtime; horizontal scaling needs externalized/stateless session storage since any instance can serve any request.
- IMDS endpoint: **169.254.169.254**. **IMDSv1** is a plain unauthenticated GET, vulnerable to SSRF-based credential theft. **IMDSv2** requires a PUT for a hop-limited token first — naive SSRF usually can't forge the PUT. Instances can be configured to require IMDSv2.

> 💡 **EXAM TRIGGER**
>
> "Harden against credential theft via a web app vulnerability" → enforce IMDSv2.

09 · Containers & ECS

ECS concepts

- Stack: container definition (image + ports) → task definition (bundles container defs + CPU/mem + networking + task role) → task (a running instance, not self-healing) → service (wraps tasks for scaling/restart/load balancing — anything business-critical is a Service, not a bare Task).

> 💡 **EXAM TRAP: TWO ROLES, EASILY CONFUSED**
>
> **Task role** is assumed by your app code inside the container for its own AWS API calls. **Task execution role** is assumed by the ECS agent itself, before the app starts, to pull the image from ECR and ship logs to CloudWatch. "Fails to pull image / can't ship logs" is an execution-role problem, not a task-role problem.

EC2 vs. Fargate cluster modes

- EC2 mode: your VPC, your EC2 hosts run the ECS agent, billed for hosts regardless of idle time, can use RI/Savings Plans/Spot pricing — more admin overhead for more cost control.
- Fargate: no hosts to manage/patch/scale, billed purely for container resources consumed, each task gets its own ENI+IP injected into your VPC.
- Exam tell: "idle capacity billing"/"managing instances" → EC2 mode. "No servers to manage"/per-task billing → Fargate.

ECR

- One public + one private registry per account; repositories hold images; tags are unique within a repository.
- Scanning: **Basic** (CVE check on push/on-demand, billed via ECR) vs. **Enhanced** (continuous, layer-by-layer, billed via Amazon Inspector).

EKS 101

- AWS-managed control plane (including etcd) across multiple AZs, always AWS-managed regardless of node type.
- Node types: self-managed EC2 in an ASG, managed node groups (still EC2, AWS handles lifecycle), or Fargate (no nodes at all).
- Two-VPC architecture: an AWS-managed VPC for the control plane + your VPC for worker nodes, connected via ENIs.

> 💡 **EXAM TELL**
>
> "Avoid vendor lock-in" / "already runs Kubernetes elsewhere" → EKS over ECS, even though ECS is the more AWS-native option.

10 · Advanced EC2

Bootstrapping

Approach	Trade-off
User data	Runs once at launch only, opaque to EC2, 16 KB cap, never put long-term credentials in it
cfn-init	Desired-state config; can re-apply on stack updates if configured to watch metadata
AMI baking	No post-launch time at all, sacrifices runtime flexibility
Bake + bootstrap	Optimal: bake the slow static 90%, bootstrap the fast variable 10%

- **CreationPolicy + cfn-signal**: without it, CloudFormation marks a resource complete as soon as EC2 reports "provisioned," regardless of whether bootstrapping inside actually succeeded.

> 💡 **CLASSIC TRAP: INSTANCE ROLE VS. INSTANCE PROFILE**
>
> A role can't attach to an EC2 instance directly — the **instance profile** (a thin wrapper) is what actually attaches. The console hides this by silently creating a same-named profile when you make a role; CLI/CloudFormation require creating both separately.

- **SSM Parameter Store**: String / StringList / SecureString (KMS-encrypted — reader needs both Parameter Store *and* the CMK permission). Hierarchical paths allow scoped IAM permissions per branch.
- **CloudWatch agent**: without it, CloudWatch only sees EC2's external face (CPU, network, status checks) — no memory-per-process or app/OS logs. One log group per log file, one log stream per instance.

Placement groups

Type	Scope	Cap	Use
Cluster	Single AZ, same rack	—	Max performance (10 Gbps single-stream), lowest latency; almost zero resilience
Spread	Can span AZs	**7 instances per AZ**	A handful of critical independent instances (domain controllers); fully automatic isolation
Partition	Per AZ	**7 partitions per AZ**, unlimited instances/partition	Large topology-aware distributed systems (HDFS/HBase/Cassandra)

Dedicated Hosts & networking

- Whole physical server billed to you, for per-socket/per-core software licensing. Non-Nitro hosts are fixed to one instance size; Nitro hosts mix sizes freely.
- Enhanced networking (SR-IOV) and EBS-optimized are both free and default-on on modern instance types.

11 · Route 53 & Global DNS

Hosted zones & CNAME vs. Alias

- Public hosted zone: 4 Route 53 name servers, reachable from the public internet and from inside any VPC. Private hosted zone: same mechanics, but only resolvable from VPCs explicitly associated with it — both conditions must hold.
- **Split-view (split-horizon) DNS**: one private zone (full record set) + one public zone (subset) under the identical domain name.

	CNAME	Alias
Works at zone apex?	**No, never** (DNS-standard limitation)	**Yes**
Cost for AWS-target queries	Billed	**Free**
Standard	DNS standard	Route 53-only extension

Default to **alias** for anything pointing at an AWS resource (ELB, CloudFront, API Gateway, S3 website bucket, Global Accelerator) — apex or not, it's free and it's the only way to do apex.

The six routing policies ⚡ HIGH YIELD

Policy	Health checks?	One-liner
Simple	**No** — only policy without HC support	Multiple values under one name, returned all, client picks. Default; no intelligence.
Failover	Yes (on primary)	Primary/secondary, active-**passive**. Not for many interchangeable resources.
Multivalue	Yes (per record)	Up to 8 healthy records returned. Active-**active**, cheap DNS-level availability — not a real load balancer.
Weighted	Optional	`weight ÷ total weight` = return probability; weight 0 = never returned. Canary/A-B testing, simple load balancing.
Latency	Yes	Region-tagged records; picks the lowest-*estimated-latency* Region for the querying user. Optimizes for performance, not distance.
Geolocation	Optional	Tagged by subdivision/country/continent; strict match order, **no match = no answer at all**. About compliance/relevance, not proximity.
Geoproximity	Optional	Tagged by Region or lat/long; routes to the physically **closest** resource; **bias** can expand/shrink a resource's catchment area.

> 💡 **THE TRAP TRIO**
>
> Latency, Geolocation, and Geoproximity are explicitly the three most likely to blur together. Latency = fastest estimated performance. Geolocation = explicit relevance match or nothing. Geoproximity = actual distance, tunable with bias.

Health checks & DNSSEC

- Three types, increasing rigor: TCP → HTTP/HTTPS (2xx/3xx) → HTTP/HTTPS + string match in the first 5,120 bytes of the body.
- **18% threshold**: more than 18% of health checkers reporting healthy = overall healthy.
- Registrar (registration fee, points the TLD at your NS records) vs. hosting (allocates the 4 NS, holds the zone file) are separate jobs — a common real pattern is hosting-only: keep a third-party registrar, point its NS records at Route 53.

- DNSSEC: KSK lives in KMS, hard-required in us-east-1 regardless of the zone's Region. ZSK is Route-53-internal, no KMS involved. DNSSEC caps hosted-zone TTLs at 1 week max.

12 · Relational Database Service (RDS) & Aurora

This workspace's own scenario-question weighting deliberately gives the intro topics (relational fundamentals, NoSQL models, ACID vs. BASE) minimal coverage and everything from "databases on EC2" onward the full treatment — that's a reasonable signal for where exam weight actually lives.

Foundations (light exam weight)

- NoSQL models: key-value (ElastiCache) / wide-column (DynamoDB) / document (DocumentDB) / column-OLAP (Redshift) / graph (Neptune — "social media"/"complex fluid relationships" scenarios).
- CAP theorem: **ACID** → **RDS** (consistency-first). **BASE** → **NoSQL** (availability-first). DynamoDB defaults BASE but offers strongly-consistent reads on request.
- Databases on EC2 is sometimes the *correct* exam answer — when you need OS-level/root DB access or an engine/version RDS doesn't offer. Don't assume it's always wrong.

RDS architecture essentials

- "Database *server* as a service" — one instance can host multiple databases, no SSH/OS access (exception: RDS Custom).
- Lives inside a VPC via a DB subnet group spanning ≥2 AZs. Each instance has dedicated EBS-backed storage (contrast with Aurora's shared cluster storage).

Multi-AZ instance vs. Multi-AZ cluster vs. Read Replica

⚡ THE CORE RDS DECISION POINT

	Multi-AZ instance	Multi-AZ cluster	Read replica
Replication	**Synchronous**, storage-level	Synchronous via transaction logs	**Asynchronous**
Standby usable for reads?	**No**	**Yes** — 2 readers	**Yes**
Failover	Automatic, 60–120 sec	Automatic, ~35 sec (log-replay, faster)	**Manual promotion required**
Cross-Region?	No	No	**Yes**
Count	1 standby	2 readers	Up to **5 direct replicas** (chainable, lag compounds)

> 💡 **ONE-RULE SHORTCUT**
>
> Synchronous = Multi-AZ (either flavor). Asynchronous = read replicas. This resolves a large share of RDS questions on its own. Read replicas are for read scaling and fast RTO on failure — **not** for corruption recovery (corruption replicates too; use point-in-time restore instead).

Aurora

- 1 writer + up to 15 replicas, **all** usable for reads (unlike RDS's standby) — Multi-AZ availability and read-scaling in one.
- Shared cluster storage volume: 6 storage nodes across 3 AZs, self-healing.
- **Backtrack** (roll the cluster back in place) and **Fast clone** (new DB referencing original storage, stores only diffs) are Aurora-only recovery features.

> ⚠ **STALE COURSE FIGURES, CORRECTED**
>
> Aurora max cluster storage: course says 128 TiB, current AWS is **up to 256 TiB**. Aurora Global Database secondary Region limit: course says 5, current AWS allows **up to 10**.

- **Aurora Serverless**: ACU min/max range instead of instance classes, can scale to zero, per-second billing — good for infrequent/spiky workloads and dev/test.
- **Aurora Global Database**: primary Region + read-only secondary Regions, storage-layer replication <1 second, one-way (distinguishes it from multi-master's bidirectional model). Use for cross-Region DR and global read scaling.

RDS Proxy

- Sits between app and DB, maintains a long-lived connection pool, **multiplexes** many client connections onto fewer real DB connections — matters most for small/burstable instances and **Lambda** (avoids per-invocation connection overhead).
- VPC-only, multi-AZ, not internet-reachable. **Headline fact:** reduces Aurora failover time by roughly 60–67% vs. connecting directly.

RDS data security & RDS Custom

- Encryption at rest options: KMS+EBS (host-level, all engines, default), TDE (engine-level, SQL Server/Oracle only), TDE+CloudHSM (Oracle only, zero key visibility to AWS). Encryption is one-way — can't be removed once enabled.
- **IAM DB authentication is authentication only, not authorization** — classic exam trap. The DB user's own grants still govern permissions.
- RDS Custom fills the gap between RDS (no OS access) and EC2 (own everything) — but **only Oracle and SQL Server** are supported. Need low-level access on MySQL/MariaDB/PostgreSQL → the answer is EC2, not RDS Custom.

Database Migration Service (DMS)

- **At least one endpoint must be in AWS** — can't migrate on-prem→on-prem. This is the default correct answer for "migrate a DB, zero downtime" scenarios.
- Task types: Full load / Full load + CDC (ongoing changes captured, cutover when caught up) / CDC only.
- **Schema Conversion Tool (SCT)** is needed only when the database engine changes (e.g. on-prem SQL Server → RDS MySQL). Same-engine migrations need no SCT.

13 · Network Storage & Data Lifecycle

EFS ⚡ REDDIT-FLAGGED

- **File storage** (NFSv4), not block storage — multiple **Linux-only** instances mount concurrently. Windows shared storage needs FSx instead.
- Access via mount targets (ENIs in specific subnets) — one mount target per AZ for HA, same pattern as NAT Gateway.
- Performance modes: General Purpose (default, latency-sensitive) vs. Max I/O (highly parallel, higher aggregate throughput, higher latency). Throughput modes: Bursting (default, scales with FS size) vs. Provisioned (independent of stored data size).
- Storage classes: Standard vs. **Infrequent Access (IA)**, with lifecycle policies auto-transitioning — mirrors S3's model.

AWS Backup

- Centralizes backup across EC2/VMware, EBS, EFS/FSx, RDS/Aurora/DynamoDB/Neptune/DocumentDB, S3 — one place for schedule/retention, cross-account via Organizations, cross-Region copy.
- Backup Plans (schedule, window, lifecycle to cold storage, expiry) + Backup Resources + Vaults. **Cold storage transition needs a 90-day minimum stay** before it can expire.
- **Vault Lock (WORM)**: 72-hour cool-off after enabling, then nobody — including AWS — can delete early. A distinct product from S3 Object Lock despite the same WORM idea.

14 · High Availability & Scaling

ELB family & architecture

- CLB (v1) is never the right exam answer today. ALB (v2, L7 — HTTP/HTTPS/WebSocket), NLB (v2, L4 — TCP/TLS/UDP), GWLB (L3/4, third-party appliance scaling).
- One LB "object" = multiple nodes (1+ per AZ subnet you pick); a single DNS record resolves to every node. Internet-facing vs. internal only changes **node** IP addressing — an internet-facing LB can forward to fully-private back-end instances.
- **Cross-zone load balancing** fixes uneven per-instance load from uneven instance counts across AZs — default-ON for ALB today, but historically wasn't. Uneven load across instances → check this setting before adding more load balancers.

ALB vs. NLB

Memorize NLB triggers, default to ALB otherwise. Pick **NLB** only for: unbroken end-to-end TLS pass-through, static IP whitelisting, absolute max performance, non-HTTP/HTTPS protocols, or PrivateLink (NLB is the mechanism PrivateLink uses). ALB always terminates HTTPS (bridging) and does true L7 routing (host header, path, method, query string, source IP).

Auto Scaling Groups

- Launch configurations vs. launch templates: only templates support versions, mixed instance types/Spot+On-Demand, and newer features.
- Min/Desired/Max triple; self-healing works even with zero scaling policy — the cheapest HA pattern is min=desired=max=1 across multiple AZ subnets.

> **⚠ STALE COURSE FACT, CORRECTED**
>
> Launch Configurations are **fully deprecated for new accounts since Oct 2024** (console-blocked since June 2023) — the lessons frame them as merely "older but fine." May still appear in scenarios describing legacy environments.

Scaling policy	Behavior
Simple	Static fixed adjustment tied to one alarm threshold
Step	Tiered adjustment proportional to how far the metric is from target
Target tracking	Most hands-off — set a target value (e.g. avg CPU 40%), ASG computes whatever scaling is needed

- **Lifecycle hooks** insert a `:Wait` state at launch/termination, default timeout 3,600 seconds, integrate with EventBridge or SNS.
- Health check source: EC2 status checks (default) vs. ELB checks (richer, app-aware) — be deliberate, since a check depending on the DB will mass-replace every instance if the DB is the real problem.
- **Health check grace period**: default 300 seconds. A grace period shorter than real bootstrap time causes an infinite replacement loop — the classic exam scenario fix is to lengthen the grace period.

SSL handling & Gateway Load Balancer

Mode	LB sees plaintext?	Instance crypto overhead?
Bridging (ALB default)	Yes	Yes
Pass-through (NLB TCP listener only)	No	Yes
SSL offload	Yes	No

- Gateway Load Balancer runs/scales third-party security appliances (firewalls, IDS/IPS) transparently. **Geneve** tunneling is the keyword to associate with GWLB — it encapsulates the original packet so source/dest IP:port survive being routed to a different VPC's appliance fleet.

15 · Serverless & Application Services

AWS Lambda

- Memory 128–10,240 MB (CPU scales with memory automatically, not set directly). **Timeout: 900 seconds (15 min) hard ceiling** — need longer, use Step Functions.
- Two networking modes: public (default, reaches public AWS endpoints + internet, not VPC-private resources) vs. VPC-attached (reaches VPC resources, needs NAT+IGW or VPC endpoints for internet/public AWS services). Current architecture uses one ENI per unique subnet+SG combination, created at config time — VPC-attached Lambda is no longer a cold-start trap.

> 💡 **EXAM TRAP: TWO PERMISSION LAYERS**
>
> **Execution role** = what the function's code can do. **Resource-based policy** = who/what can invoke the function (cross-account, S3, SNS). With event source mapping (SQS/Kinesis/DynamoDB Streams), the *execution role* — not a resource policy — needs permission on the source, since the mapping polls on the function's behalf.

- Invocation types: synchronous (caller blocks, caller retries), asynchronous (Lambda auto-retries 0–2x, can route to DLQ/destinations), event source mapping (polling component, configurable retries per source).
- Versions are immutable snapshots; `$LATEST` is mutable; aliases are mutable named pointers — **production traffic should target aliases, never $LATEST**. Provisioned concurrency pre-inits execution contexts to eliminate cold starts (applies to a version/alias, never $LATEST).

EventBridge, SNS & Step Functions

- EventBridge = CloudWatch Events v2, same API, adds custom/third-party event buses and richer routing. Exam signal: third-party SaaS or custom application events → EventBridge, not plain CloudWatch Events.
- **SNS**: pub/sub, message up to 256 KB. **Fan-out pattern (one topic → multiple SQS queues, each with its own worker pool) is a very high-yield exam pattern** — memorize it. SNS pushes; SQS pulls/holds.
- **Step Functions** solve Lambda's 15-minute ceiling and statelessness for multi-step workflows. **Standard** (1-year max, exactly-once, auditable) vs. **Express** (5-minute max, at-least-once, high-volume event processing).

API Gateway

Type	Fit
REST API	Full-featured: usage plans, API keys, per-client throttling, WAF integration, private endpoints
HTTP API	Cheaper/lower-latency, simple Lambda/HTTP proxy, built-in CORS
WebSocket API	Persistent bidirectional (chat, live dashboards)

- 29-second integration timeout is still fixed for edge-optimized APIs; since 2024 it can be raised via Service Quotas for Regional and private REST APIs.

SQS ⚡ HIGH YIELD

- **Visibility timeout** is the single most-tested SQS detail: a poll hides a message (doesn't delete it) — if not explicitly deleted before the timeout expires, it silently reappears.

	Standard	FIFO
Ordering	Best effort	Strict
Delivery	At-least-once (dupes possible)	Exactly-once
Throughput	Near-infinite	300/sec (3,000/sec batched, or higher with high-throughput mode)
Naming	None	Must end `.fifo`

	Visibility timeout	Delay queue
Message starts as	Visible	Invisible
Hidden when	After a consumer receives it	Immediately on send
Purpose	Automatic reprocessing on failure	Deliberate delay before any consumer sees it
Range	0s–12h (default 30s)	0s–15min (default 0)

- **Dead-letter queues**: a redrive policy on the source queue sets a target DLQ + `maxReceiveCount`. The enqueue timestamp carries over unchanged — always configure DLQ retention longer than the source queue's, or messages can be dropped before anyone investigates.

Kinesis family

- **Data Streams**: shard = unit of scale (1 MB/sec ingest, 2 MB/sec consume). Kinesis for ingestion at scale (IoT/clickstreams, many producers/consumers); default to SQS for decoupling/worker pools.
- **Amazon Data Firehose** (renamed from Kinesis Data Firehose, Feb 2024): near real-time, not real-time — buffers on 1 MB or 60 seconds, whichever first. Any Firehose-involved answer cannot be the real-time solution.
- **Amazon Managed Service for Apache Flink** (renamed from Kinesis Data Analytics, Aug 2023): its SQL-only variant is fully discontinued (blocked new apps Oct 2025, deleted Jan 2026) — teach the "real-time SQL/stream processing" concept regardless of which name the question uses.
- **Kinesis Video Streams**: the only Kinesis product for media/time-serialized data — you cannot access underlying storage directly, only via the service's own APIs.

Cognito: User Pools vs. Identity Pools ⚡ HEAVILY TESTED NAMING TRAP

	User Pool	Identity Pool
Job	Sign-up/sign-in/user directory	Swap identity for AWS credentials
Output	JWT	Temporary AWS credentials (via IAM role)
Grants AWS access?	**No**	**Yes** — its entire purpose

The single most important fact: a user pool JWT cannot access most AWS services — that's identity pools' job. Swapping an external IdP token for AWS credentials is Web Identity Federation.

Glue, Amazon MQ & AppFlow

- **Glue**: serverless ETL. Its Data Catalog (crawlers populate it by inferring schema) is also read by Athena, Redshift Spectrum, and EMR — seeing "schema discovery" alongside those services signals Glue. Data Pipeline is closed to new customers (July 2024); Glue is now the default answer.
- **Amazon MQ**: for migrating existing on-prem brokers (JMS/AMQP/MQTT/STOMP) speaking ActiveMQ or RabbitMQ without app rewrites. **Not a public service — runs inside a VPC.** Default to SNS/SQS for new AWS-native work.

- **AppFlow**: managed no-code middleware for SaaS↔AWS data exchange (e.g. Salesforce → Redshift) — not general ETL (that's Glue), not hand-built integration.

16 · Global Content Delivery & Optimization

CloudFront architecture

- Origin → Distribution (gets a `*.cloudfront.net` domain) → Edge locations (cache, no EC2 deployable there) → Regional edge caches (between edge locations and origin).
- **CloudFront is read-only caching** — uploads always go directly to the origin. **Distributions don't hold config directly — behaviors do**, and more specific path-pattern behaviors take priority over the default.

Distribution-level	Behavior-level (can differ per path)
Price class, WAF association, alternate domain names, SSL cert type	Origin/origin group, viewer protocol policy, allowed HTTP methods, cache settings/TTLs, public/private restriction, Lambda@Edge

TTL, invalidations & ACM

- **Invalidation** immediately expires matching objects everywhere regardless of remaining TTL — not free at volume, not instantaneous. Treat as mistake-correction, not routine deployment tooling.
- **Better pattern: versioned filenames** (e.g. `whiskers_v2.jpg`) — no invalidation cost, works even for browser-cached copies. Very common "most cost-effective content rollout" exam answer.
- **ACM renewal**: ACM-generated certs auto-renew; imported certs must be manually renewed and re-imported. Only CloudFront and load balancers can use ACM certs — **EC2 is explicitly not supported**, must install manually. ACM is regional, except CloudFront, which **always requires the cert in us-east-1** regardless of the distribution's actual traffic Region.

Securing the origin: OAI vs. OAC

- **OAC has superseded OAI** as AWS's recommendation — OAC supports opt-in Regions, SSE-KMS, and dynamic requests (PUT/POST/DELETE), which OAI doesn't. Both work only for S3 origins — custom origins use custom headers and/or IP allow-listing instead.
- **Signed URL = one object. Signed cookie = a group of objects.** Private behaviors secure the viewer side only — the origin still needs OAI/OAC to prevent bypass.

Lambda@Edge vs. CloudFront Functions

- Four hook points: viewer request, origin request, origin response, viewer response.
- **CloudFront Functions** (newer, not in the original course): JavaScript only, viewer-side hooks only, sub-millisecond startup, extremely high scale — best for cache-key normalization, header manipulation, simple

redirects. Lambda@Edge is still needed for anything origin-side, filesystem access, or request body.

CloudFront vs. Global Accelerator ⚡ HIGH YIELD

	CloudFront	Global Accelerator
Layer	Content delivery (caching)	Network (raw packet routing)
Protocols	HTTP/HTTPS only	**Any TCP or UDP**
Caches content?	Yes	**Never**
HTTP-aware?	Yes (headers, cookies, paths)	No — no HTTP concept at all

> 💡 **FAST FILTER**
>
> Caching / signed URLs / HTTP-specific behavior → CloudFront. TCP/UDP (especially non-HTTP, e.g. gaming protocols) / pure network performance with no caching mentioned → Global Accelerator. GA uses two static Anycast IPs and rides AWS's private backbone for most of the journey — it improves performance by minimizing the public-internet leg, not by "making the internet faster."

17 · Advanced VPC Networking

VPC Flow Logs

- **Metadata only — never packet contents.** Attachment levels: VPC > Subnet > ENI, each capturing everything downstream. Not real-time.
- **Reading accept/reject pairs reveals which firewall acted**: Security Groups are stateful → typically one log line per conversation. NACLs are stateless → a NACL blocking only the return leg produces two lines (accept + reject) for what looks like one flow.

Egress-Only Internet Gateway

- Solves: giving IPv6 the same "outbound-only" behavior NAT gives IPv4. NAT is fundamentally an IPv4-only workaround for address scarcity — every IPv6 address is publicly routable, so there's no "private IPv6."
- A plain IGW lets IPv6 flow both ways; an egress-only IGW blocks internet-initiated inbound while still allowing outbound-initiated traffic and its return (stateful).

Gateway Endpoint vs. Interface Endpoint ⚡ HIGH YIELD

	Gateway endpoint	Interface endpoint
Mechanism	Route table + prefix list	ENI + DNS (built on PrivateLink)
Services	**S3 and DynamoDB only, ever**	Everything else (S3 also optionally)
HA	Automatic, all AZs	Manual — one per AZ needed
Security groups?	No	**Yes** (it's an ENI)
Cost	Free	Hourly + data charges

> 💡 **EXAM SIGNAL**
>
> A fully private VPC (no IGW, no NAT) needing S3/DynamoDB access → gateway endpoint. Access control: an endpoint policy plus a matching S3 bucket policy (only accept requests via that endpoint) together make a fully private bucket.

VPC Peering

- **Exactly two VPCs per connection, never more, and not transitive** — A↔B and B↔C gives no A↔C connectivity. N VPCs full-mesh needs N(N-1)/2 connections; Transit Gateway is the scalable alternative.
- A peering connection needs (1) acceptance, (2) route table entries in both VPCs, (3) SG/NACL rules permitting the traffic. **Overlapping CIDR ranges block peering entirely** — no workaround.

18 · Hybrid Environments & Migration

One exam report names this module's territory directly — Transit Gateway, Microsoft AD with on-prem integration, on-premises storage, and "Snowball vs. Direct Connect" as a core tested domain. Treat this as the highest-priority module in the whole cheat sheet.

AWS Site-to-Site VPN ⚡ HIGH YIELD

- Core components: VPC ↔ Virtual Private Gateway (VGW) ↔ VPN connection ↔ Customer Gateway (CGW).
- **HA progression**: 1 VGW + 1 CGW = 2 tunnels but a single CGW is a single point of failure ("partial HA"). Add a 2nd CGW at a separate premises/ISP + 2nd VPN connection for full HA.
- Static (manually configured routes) vs. Dynamic (BGP-exchanged, supports failover/load-balancing).
- **Throughput cap: 1.25 Gbps per connection and per VGW aggregate** — the single most tested number here. Newer options past the cap: Accelerated Site-to-Site VPN and Large Bandwidth Tunnels (5 Gbps/tunnel, TGW-attached only).

Direct Connect ⚡ HIGH YIELD

- A dedicated **physical** connection into an AWS Region. Ordering DX is a port allocation only — AWS does not run a cable to you.

> 💡 **EXAM TRAP**
>
> DX locations are **not AWS-owned** — they're third-party data centers where AWS leases a cage, and you (or a comms partner) separately lease space there.

- Port speeds: 1/10/100/400 Gbps. Billing = hourly port charge + *outbound* data transfer (inbound is free). **No built-in resilience** — one physical cable — and slow to provision (weeks–months).
- Virtual Interfaces: Private VIF → VGW/private VPC resources; Public VIF → AWS public-zone services or any public IP (including a VPN endpoint); Transit VIF → Transit Gateway. **DX cannot reach the general internet, ever.**
- **Resilience progression**: single DX has 7 single points of failure → 2 ports/1 location/1 premises tolerates router/cable failure only → 2 locations/2 premises tolerates a full location failure → maximum resilience = 2 locations × 2 ports each × 2 premises.

> 💡 **HIGH-YIELD EXAM TRAP**
>
> A VPN into a **private** VPC over Direct Connect still needs a **public** VIF, not private — because the VPN endpoint (VGW/TGW) has a public IP address, and a private VIF only reaches private IPs.

Transit Gateway ⚡ REDDIT EXPLICITLY FLAGS 1–2 TGW QUESTIONS

- **The key differentiator: TGW supports transitive routing; VPC peering does not.** Full-mesh peering for N VPCs explodes in connection count — TGW replaces that with one hub.
- Three facts to memorize: transitive routing, TGW peering works cross-Region and cross-account riding AWS's global network, and it's shareable via AWS RAM across accounts.

Storage Gateway ⚡ ON-PREM STORAGE DECISION TREE

Mode	Protocol	Primary/authoritative copy	Best for
Volume Gateway — Stored	iSCSI	On-premises	Backup/DR (not capacity relief)
Volume Gateway — Cached	iSCSI	S3	Data center extension, PB-scale with modest local cache
Tape Gateway (VTL)	iSCSI (virtual tape)	S3 (active) / Glacier (archived)	Replacing physical tape backup hardware, keeping existing backup software
File Gateway	NFS / SMB	S3	File shares mapped 1:1 to an S3 bucket

> 💡 **EXAM HEURISTIC**
>
> "Volume"/iSCSI → Volume Gateway (then backup/DR → stored, capacity relief → cached). "Tape" → Tape Gateway, essentially without exception. "File"+NFS/SMB → File Gateway (S3 is primary here too — same mental model as Cached mode, opposite of Stored mode).

Snow family, DataSync & the "no viable network" decision ⚡ REDDIT CORE DOMAIN

> ⚠ **CURRENT-REALITY FLAG**
>
> The entire **Snow family closed to new customers Nov 7, 2025** (Snowcone discontinued Nov 2024, Snowmobile retired ~2024). Only existing Snowball Edge customers can still order; AWS now points new customers to DataSync or the AWS Data Transfer Terminal. The exam still tests the classic decision tree below — know it, but "just order a Snowball" isn't actually orderable today for a new customer.

- **Snowball** (storage only): 50/80 TB, sweet spot ~10 TB–10 PB. **Snowball Edge** (storage + compute): choose when you need to process data as it's ingested. **Snowmobile**: a literal shipping container, up to 100 PB, single-site only.
- **DataSync**: managed, automated, scheduled/incremental transfer over an *existing* network link — 10 Gbps per agent-based task (~100 TB/day). AWS-to-AWS Basic mode caps at 25 million files/task (a newer Enhanced mode supports far more).

> 💡 **EXAM HEURISTIC**
>
> DataSync = reliable/incremental/scheduled transfer with a working network link. Snowball/Edge = huge one-time bulk transfer with **no** viable network path. Multiple sites with moderate data each → multiple Snowball devices (never Snowmobile); a single site >~10 PB → Snowmobile.

AWS Directory Service ⚡ REDDIT-FLAGGED: AD WITH ON-PREM INTEGRATION

Mode	Directory data stored in AWS?	On-prem integration
Simple AD	Yes (Samba 4, isolated)	None — no trust relationships
AWS Managed Microsoft AD	Yes (real AD)	Optional two-way trust over VPN/DX
AD Connector	No — pure proxy	Required continuously — fails entirely if the link drops

> 💡 **DECISION ORDER**
>
> Simple AD for isolated/no-integration needs → Managed Microsoft AD for real-schema or trust-relationship needs → AD Connector only when directory data must never touch AWS at all.

> ⚠ **CURRENT-REALITY FLAGS**
>
> Simple AD closes to new customers **July 30, 2026**. AWS Managed Microsoft AD now runs **Windows Server 2019** (was 2012 R2).

FSx for Windows vs. FSx for Lustre ⚡ REDDIT-FLAGGED

> 💡 **THE HIGHEST-YIELD FACT IN THIS PAIR**
>
> SMB/Windows/AD keywords → FSx for Windows File Server. NFS/Linux/HPC/ML/SageMaker keywords → FSx for Lustre. EFS has zero Windows story at all.

- **FSx for Windows**: native Windows file system, AD-integratable with either AWS Managed Microsoft AD or a self-managed AD, native Deduplication/DFS/VSS/NTFS permissions. Throughput ceiling raised to 12 GB/s.
- **FSx for Lustre**: HPC-oriented, scales to hundreds of GB/s.

Lustre deployment	Resilience	Best for
Scratch	No replication — hardware failure loses data	Short-term/temp, speed over durability
Persistent	Replicated within one AZ (not multi-AZ), self-healing	Longer-term, hardware-failure resilience

> ⚠ **EXAM TRAP, WITH A CURRENT-REALITY NUANCE**
>
> Persistent is single-AZ, not multi-AZ — but Persistent 2 with Intelligent-Tiering now replicates across multiple AZs. SAA-C03 depth still treats Persistent as single-AZ; know both.

AWS Transfer Family

Endpoint	Protocols	SG/NACL control
Public	SFTP only	None
VPC, internet-facing	SFTP, FTPS, AS2	Yes
VPC, internal only	SFTP, FTPS, **FTP**, AS2	Yes

Plain FTP is unencrypted — only allowed on the VPC internal-only endpoint, never public or internet-facing.

19 · Security, Deployment & Operations

Secrets Manager vs. Parameter Store

> 💡 **KEYWORD HEURISTIC**
>
> "Secrets"/API keys/passwords → Secrets Manager. "Rotation" (especially paired with RDS) → Secrets Manager, since Parameter Store cannot do automatic in-sync rotation at all. Plain hierarchical non-sensitive config → Parameter Store.

WAF ⚡ DDOS-PROTECTION TOPIC

- Protects CloudFront (global), ALB, AppSync, API Gateway (regional — the Web ACL must be created in the same Region as the resource).
- One resource : one Web ACL, but one Web ACL : many resources. WCU ceiling is now 5,000 with no ticket needed (course-era figure was 1,500-with-ticket).
- Rate-based rules have **no "allow" action** — only block/count/CAPTCHA.

AWS Shield ⚡ THE DDOS-PROTECTION DECISION POINT

DDoS category	OSI layer
Network volumetric	L3
Network protocol (e.g. SYN floods)	L4
Application layer	L7

- **Shield Standard**: free, automatic, no config, covers L3/L4, strongest when traffic flows through Route 53/CloudFront/Global Accelerator.
- **Shield Advanced**: $3,000/month billed *per AWS Organization* (not per account), extends to L7 via WAF integration, adds cost protection and 24/7 Shield Response Team engagement.

> 💡 **EXAM TRAP**
>
> Shield Advanced protections are **not automatic** — must be explicitly enabled per resource. Subscribing alone protects nothing. SRT proactive engagement additionally requires health-based detection (Route 53 health checks) configured first.

Decision summary: Standard = free/automatic/L3-4 baseline for everyone. Need L7/app-layer DDoS coverage, cost protection, or proactive AWS support → Shield Advanced.

CloudHSM vs. KMS

Same broad job as KMS — the exam skill is a keyword-triggered decision. Three triggers point to CloudHSM: FIPS 140-3 Level 3 for the whole appliance, industry-standard crypto APIs (PKCS#11/JCE/CNG), or an explicit single-tenant/AWS-zero-access requirement. Lives in an AWS-managed CloudHSM VPC (not yours).

Config, Macie, Inspector & GuardDuty

> 💡 **AWS CONFIG: SINGLE MOST-TESTED FACT**
>
> Config is **detective only, never preventive** — it records configuration change history but never blocks a non-compliant change. Turning detection into action needs SNS/EventBridge → Lambda/SSM Automation layered on top.

Service	Lane
GuardDuty	Continuous ML/threat-intel anomaly detection, whole account — not a triggered scan, not data classification
Macie	Discovers/classifies sensitive *data* specifically inside S3
Inspector	Vulnerability/CVE scanning of *compute* (EC2, ECR images, Lambda)

- Inspector's old "Inspector Classic" (manual, duration-based) reached end of support May 2026 — current Inspector is continuous and automatic. "CVE" is still the core keyword for Inspector.
- GuardDuty's foundational data sources are DNS logs, VPC Flow Logs, and CloudTrail events, with many optional protection plans added since (EKS, RDS, Lambda, Malware Protection, AI Protection).

20 · Infrastructure as Code (CloudFormation)

SAA-C03 tests CloudFormation concepts lightly, not authoring — this section is intentionally compact.

- A **stack** keeps a template's logical resources in sync with real physical resources — update the stack and CFN diffs/adds/modifies/deletes to match; delete the stack and the physical resources go too.
- Key intrinsic functions: `Ref` (main value), `Fn::GetAtt` (secondary attribute), `Fn::GetAZs` + `Fn::Select`, `Fn::Join` / `Fn::Split`, `Fn::Sub` (can't reference the resource's own attributes, since it doesn't exist yet), `Fn::Cidr`.
- **DependsOn**: CFN auto-infers dependencies from `Ref` / `GetAtt` / `Sub` references. Classic exam scenario: an Elastic IP requiring an attached Internet Gateway, where nothing in the EIP's properties references the attachment — CFN can't infer it, so you need an explicit `DependsOn`.
- **CreationPolicy** (max timeout 12 hours) closes the gap where CFN marks a resource complete the moment EC2 reports "provisioned," regardless of whether bootstrapping inside actually succeeded — the instance calls `cfn-signal` when it's really done.

	Nested Stacks	Cross-Stack References
Reuses	A **template** — each use creates a fresh physical resource	An actual **resource** — the same physical thing shared
Use when	Everything is lifecycle-linked	Consumers have independent/shorter lifecycles than the shared resource
Limits	Helps beat the 500-resources-per-stack cap	Same Region + same account only

- **DeletionPolicy** (Delete/Retain/Snapshot) only covers deletion, not replacement — a newer `UpdateReplacePolicy` attribute covers that gap.
- **Change Sets** preview the delta (no interruption / some interruption / replacement, including potential data loss) before executing an update — creating one touches nothing physical.
- **Custom Resources** are the escape hatch for anything CFN can't do natively, backed by a Lambda or SNS `ServiceToken`.

21 · NoSQL Databases & DynamoDB

Architecture & capacity ⚡ REDDIT-FLAGGED

- Database-*as-a-service* (no server to size/patch, contrast with RDS's database-*server*-as-a-service). Public service, reachable via internet or a gateway VPC endpoint.
- Item size limit: **400 KB** max. **1 WCU** = one write ≤1 KB/sec. **1 RCU** = one strongly-consistent read ≤4 KB/sec. Every operation consumes at least one whole unit, rounded up.
- **Standard-IA table class**: ~60% storage cost cut vs. Standard, identical performance/durability, switchable without code changes.

Query vs. Scan, consistency

- **Query** requires exactly one partition key value (plus optional sort-key filter) — the cheapest way to get multiple items. **Scan** walks the entire table and bills for every item scanned, matched or not.
- Every item replicates to 3 storage nodes across 3 AZs with one elected leader; all writes go to the leader first. **Eventually consistent reads** (default) can hit any node, half the RCU cost. **Strongly consistent reads** always hit the leader, full RCU cost.

> 💡 **EXAM TRAP**
>
> Staleness-sensitive data (financial, inventory, medical) → strongly consistent reads. Watch for per-minute rates in a capacity-math question — convert to per-second first.

LSI vs. GSI

	LSI	GSI
Partition key	Same as base table	Independent, chosen freely
Created	**Only at table creation**	Any time
Capacity	Shared with base table	Own separate RCU/WCU
Consistency	Eventual **or** strong	**Eventual only, always**
Default limit	5 per table	20 per table

Default guidance: unsure → GSI (flexible, independent capacity). Need strong consistency on the alternate access pattern → LSI, the one thing GSI structurally can't do.

Streams, Global Tables, DAX & TTL

- **Streams**: 24-hour rolling window of item-level changes, four view types (KEYS_ONLY/NEW_IMAGE/OLD_IMAGE/NEW_AND_OLD_IMAGES). Streams + Lambda = a fully event-driven trigger, zero polling.
- **Global Tables**: multi-Region, "multi-active" replication (renamed from "multi-master"), last-writer-wins conflict resolution. Same-Region as the write → strong or eventual reads possible; different Region → eventual only, no exceptions.
- **DAX**: in-memory cache purpose-built for DynamoDB, deployed inside a VPC (unlike DynamoDB itself). Item cache + query cache. **Cannot serve strongly consistent reads at all** — a hard rule-out for that requirement.
- **TTL**: the TTL attribute holds epoch seconds — once that time is past, DynamoDB auto-deletes the item via two independent background processes (expire, then delete).

Athena, ElastiCache & Redshift

- **Athena**: serverless SQL over S3, schema-on-read, pay per data scanned. Now supports Apache Iceberg tables with real INSERT/UPDATE/DELETE — "Athena only reads" is no longer an absolute rule.
- **ElastiCache**: Redis (rich data structures, true Multi-AZ HA, persistence, transactions) vs. Memcached (simple strings, no true replication, multi-threaded). **"No application changes needed" rules ElastiCache out** — the app must actively check cache, handle misses, write back.
- **Redshift**: petabyte-scale OLAP data warehouse (vs. RDS's OLTP). Classic clusters run in **one AZ** — not natively HA across AZs, though resilience comes from snapshots landing in S3. Redshift Serverless and genuine Multi-AZ (GA for RA3 clusters) now exist alongside the classic single-AZ model; the exam still tests single-AZ as the foundational architecture.

22 · Machine Learning 101

Deliberately short and high-level in the source course — architectural-level recognition only. Core pattern: ten pre-built "send data, get a result" AI APIs, plus SageMaker as the one platform for building a genuinely custom model.

Service	One-line ID
Comprehend	NLP on text: entities, key phrases, sentiment, PII detection
Kendra	Intelligent enterprise search over varied data sources
Lex	Chatbots/voice assistants (powers Alexa) — ASR + NLU, intents/slots
Polly	Text-to-speech (standard → neural → newer generative-voices tier)
Rekognition	Image/video content analysis (objects, faces, text, moderation)
Textract	Document text + structure extraction, incl. ID-document normalization
Transcribe	Speech-to-text, plus Medical and Call Analytics variants
Translate	Text-to-text translation between languages
Forecast	Time-series forecasting from historical + related data
Fraud Detector	Fraud scoring via 3 model types matched to available history
SageMaker	The one platform for custom model build/train/deploy (vs. all the pre-built APIs above)

⚠ SERVICE-LIFECYCLE CLOSURES (CONCEPTS STILL TESTABLE, PRODUCT ACCESS HAS CHANGED)

Kendra closes to new customers July 30, 2026 (steers to Bedrock Knowledge Bases). Rekognition's Streaming Video Analysis and Bulk Image Analysis closed to new customers April 30, 2026, despite the course teaching live Kinesis Video Streams analysis as core. Forecast closed to new customers July 29, 2024. Fraud Detector closed to new customers November 7, 2025. SageMaker was renamed "Amazon SageMaker AI" in December 2024, now sitting alongside sibling product Amazon Bedrock.

23 · Other Services & Features

Edge option	Sits where	Best fit
Local Zones	Near metro areas, extends a parent Region	Low-latency compute/storage/DB for one city's users
Wavelength	Inside telecom 5G networks	Ultra-low-latency mobile/5G-native apps
Outposts	Customer's own data center/colo	Full AWS infra/APIs running on-premises

> 💡 **EXAM-TRAP DETAIL**
>
> A Local Zone behaves like a single AZ with no built-in redundancy of its own. Compute/low-latency access stays local, but **EBS snapshots still land in S3 back in the parent Region** — that's what preserves their usual multi-AZ durability, and it's a favorite exam-trap detail.